IBM CYBERSECURITY PROGRAM — EDUCATIONAL PROJECT

Active Directory Attack Lab: Kerberoasting Risk Assessment & Group Policy Hardening

Project Report — Version 1.0

PROGRAM	AUTHOR	DATE	VERSION
IBM Cybersecurity Professional Certificate	[Your Full Name]	[Submission Date]	1.0.0

⚠ SCOPE STATEMENT: This project is conducted exclusively in an isolated virtual lab environment using synthetic identities. No production systems, real credentials, or live networks are involved. All findings are theoretical and educational in nature.

TABLE OF CONTENTS

1. Abstract
2. Problem Statement
3. Objectives
4. Lab Architecture
5. Methodology
6. Risk Scenarios Analysis
7. Security Controls Implemented
8. Testing Plan
9. Results Template
10. Limitations
11. Conclusion
12. References

13. Screenshot Placeholders

SECTION 1

Abstract

This project explores **Kerberoasting**, a post-exploitation attack technique that allows any authenticated domain user to request Kerberos service tickets (TGS) for service accounts with registered Service Principal Names (SPNs), and subsequently attempt offline password cracking against those tickets. The attack requires no special privileges and exploits a fundamental design characteristic of the Kerberos protocol.

This educational project develops an isolated Windows Server 2022 Active Directory lab environment using synthetic identities to document the attack surface, implement Group Policy Object (GPO) hardening, configure advanced audit policies, and deploy Group Managed Service Accounts (gMSA) to eliminate the primary attack vector. A companion Python Flask web application provides an interactive dashboard for risk scenario review, defensive control scoring, and automated risk assessment.

All work is performed exclusively in an offline, isolated virtual environment. No production systems, real credentials, or live networks are used at any stage.

SECTION 2

Problem Statement

Kerberoasting has been documented as one of the most reliably effective Active Directory attack techniques since its public disclosure in 2014. It remains prevalent because:

- The Kerberos protocol requires no special permissions to request a TGS ticket for any registered SPN
- Many organisations maintain service accounts with static, human-memorable passwords set years ago
- RC4-HMAC encryption (0x17) — the default in legacy domains — produces tickets susceptible to fast offline cracking
- Without proper audit logging, TGS enumeration for multiple SPNs is invisible in event logs
- Service accounts frequently hold excess privileges, converting a cracked password into a domain compromise

The consequences of a successful Kerberoasting attack range from service account compromise through lateral movement to full domain takeover when privileged accounts are targeted. Despite being well-understood, many enterprise environments lack the basic controls needed to detect or prevent it.

SECTION 3

Objectives

1. Build an isolated Windows Server 2022 Active Directory lab with synthetic service accounts and SPNs
2. Document and understand the Kerberoasting attack vector from a defender's perspective
3. Implement and verify AES-only Kerberos encryption enforcement via GPO
4. Deploy Group Managed Service Accounts (gMSA) to eliminate static passwords on SPN accounts
5. Configure Advanced Audit Policies to capture Event ID 4769 for detection
6. Enable PowerShell Script Block Logging to detect tool-based enumeration
7. Apply least-privilege principles and Protected Users group to Tier-0 accounts
8. Develop an interactive Flask application for risk assessment and control scoring
9. Produce verifiable evidence of defensive controls for academic submission

SECTION 4

Lab Architecture

4.1 Virtual Environment

COMPONENT	SPECIFICATION	PURPOSE
Hypervisor	Oracle VirtualBox / VMware Workstation Player	Host isolation
Network	Host-Only Adapter — 192.168.100.0/24	No internet routing
DC01	Windows Server 2022 Evaluation — 2 vCPU / 4 GB RAM	Domain Controller, KDC, DNS
CLIENT01	Windows 10/11 Enterprise Evaluation — 2 vCPU / 4 GB RAM	Domain member workstation
Domain	lab.local (non-routable)	Synthetic isolated forest

4.2 Active Directory Design

OU	CONTENTS	SPECIAL CONTROLS
OU=LabServiceAccounts	svc-sqltest (vulnerable), gmsa-sqltest (hardened)	Fine-Grained PSO, AES enforcement
OU=LabUsers	alice.lab, bob.lab, charlie.lab	Standard user policy
OU=LabWorkstations	CLIENT01	Workstation hardening GPO

4.3 Application Architecture

LAYER	TECHNOLOGY	DESCRIPTION
Web Framework	Python Flask 3.x	Local-only application server
Templates	Jinja2 / HTML5	Dark-theme responsive UI
Security	Flask-WTF CSRF, bleach	Input sanitisation and CSRF protection
Data	In-memory Python structures	No external database required
Export	Python csv module	CSV download for scenarios and checklist

SECTION 5

Methodology

5.1 Research Phase

Background research was conducted into the Kerberos authentication protocol, specifically the TGS-REQ/TGS-REP exchange, SPN registration mechanics, and the role of encryption type negotiation. Published Microsoft security guidance, MITRE ATT&CK technique T1558.003, and CIS Benchmark recommendations for Active Directory were reviewed.

5.2 Lab Build Phase

An isolated lab was constructed following the documented procedures in `ad_lab/AD_Lab_Setup.md`:

1. Configure VM network as Host-Only (no internet routing)
2. Install Windows Server 2022 and promote to Domain Controller for `lab.local`
3. Create OU structure and synthetic service accounts
4. Register SPNs on the synthetic vulnerable account (`svc-sqltest`)
5. Join CLIENT01 to the domain
6. Take snapshots to preserve the baseline (pre-hardening) state

5.3 Baseline Assessment Phase

Using the Flask application's Risk Assessment module, the pre-hardening lab state was evaluated against the documented risk factors. The baseline expected findings include:

- RC4 encryption allowed on service accounts → **CRITICAL**
- No Advanced Audit Policy for Kerberos → **HIGH**
- Static password on SPN account (no gMSA) → **HIGH**
- PowerShell logging not configured → **MEDIUM**

5.4 Hardening Phase

Defensive controls were applied in the order documented in `hardening/Security_Hardening_Baseline.md`: AES enforcement, gMSA deployment, audit policy, PowerShell logging, Protected Users group, and Fine-Grained PSO. GPO backups were taken before and after each change.

5.5 Verification Phase

Each control was verified using the PowerShell commands listed in the Hardening Verification Matrix. Post-hardening audit of Event ID 4769 encryption type fields was performed to confirm RC4 tickets were no longer being issued.

SECTION 6

Risk Scenarios Analysis

#	SCENARIO	SEVERITY	CVSS	CATEGORY
1	Service account uses RC4 encryption — no AES	CRITICAL	8.8	Encryption
2	Service account password not rotated in 12+ months	HIGH	7.5	Password Policy
3	Service account holds Domain Admin membership	CRITICAL	9.0	Privilege
4	No audit policy for Kerberos service ticket operations	HIGH	7.2	Auditing
5	Excessive SPN registrations on standard user accounts	MEDIUM	6.0	SPN Management
6	PowerShell logging not enabled on Domain Controllers	MEDIUM	5.8	Logging

SECTION 7

Security Controls Implemented

#	CONTROL	CATEGORY	METHOD	WEIGHT
1	AES encryption enforced — RC4 disabled	Encryption	GPO + msDS-SupportedEncryptionTypes	20pts
2	Group Managed Service Accounts (gMSA) deployed	Password Policy	New-ADServiceAccount	15pts
3	No service account holds privileged group membership	Privilege	AD Group Audit + Restricted Groups GPO	20pts

#	CONTROL	CATEGORY	METHOD	WEIGHT
4	Kerberos Service Ticket audit enabled (Event 4769)	Auditing	Advanced Audit Policy GPO	15pts
5	SPN inventory reviewed and cleaned	SPN Management	setspn -X + AD export	10pts
6	PowerShell Script Block Logging enabled	Logging	Admin Templates GPO	10pts
7	Protected Users group applied to Tier-0	Privilege	Add-ADGroupMember	10pts
8	GPO backup and recovery documented	GPO Management	Backup-GPO script	5pts
9	Fine-Grained Password Policy for service accounts	Password Policy	PSO via ADAC / PowerShell	10pts
10	SIEM alerts configured for Event 4769 anomalies	Monitoring	Windows Event Forwarding	10pts

SECTION 8

Testing Plan

8.1 Application Testing (Automated)

TEST	FILE	WHAT IS VERIFIED
test_index_loads	tests/test_app.py	Dashboard returns HTTP 200
test_scenarios_loads	tests/test_app.py	Scenarios page returns HTTP 200
test_scenarios_filter	tests/test_app.py	Severity filter returns filtered results
test_checklist_scoring	tests/test_app.py	POST checklist returns score 0–100
test_checklist_all_checked	tests/test_app.py	All controls checked = 100% score
test_csv_export	tests/test_app.py	CSV download returns text/csv content-type
test_risk_assessment_critical	tests/test_app.py	All risk factors = Critical level
test_api_stats	tests/test_app.py	JSON stats endpoint structure

8.2 Lab Verification Testing (Manual)

TEST	COMMAND	EXPECTED
AES enforcement	`Get-ADUser svc-sqltest -Prop msDS-SupportedEncryptionTypes`	24
gMSA health	`Test-ADServiceAccount gmsa-sqltest`	True
Audit policy	`auditpol /get /subcategory:"Kerberos Service Ticket Operations"`	Success and Failure
PS logging	Check HKLM:\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging	EnableScriptBlockLogging = 1
GPO applied	`gpresult /r /scope:computer`	Hardening GPO listed

SECTION 9

Results Template

> **Note:** This section contains a results template. Actual test results must be filled in by the student after executing lab procedures. Do not fabricate results.

📋 Complete this table after executing each control in your lab and paste your actual PowerShell output as evidence in the Screenshot Placeholders section.

CONTROL	STATUS	VERIFICATION OUTPUT	EVIDENCE
AES encryption enforced	[ ] Pass [ ] Fail	[Paste msDS-SupportedEncryptionTypes value]	Screenshot #1
gMSA deployed and healthy	[ ] Pass [ ] Fail	[Paste Test-ADServiceAccount output]	Screenshot #2
No DA in service accounts	[ ] Pass [ ] Fail	[Paste Get-ADGroupMember output]	Screenshot #3
Event 4769 audit enabled	[ ] Pass [ ] Fail	[Paste auditpol output]	Screenshot #4
PS Script Block Logging	[ ] Pass [ ] Fail	[Paste registry value]	Screenshot #5
GPO backup created	[ ] Pass [ ] Fail	[Paste backup folder listing]	Screenshot #6
Flask app tests pass	[ ] Pass [ ] Fail	[Paste pytest output]	Screenshot #7

CONTROL	STATUS	VERIFICATION OUTPUT	EVIDENCE
Checklist score >= 80%	[ ] Pass [ ] Fail	[Paste score from application]	Screenshot #8

SECTION 10

Limitations

- **Isolated lab only:** Findings are based on a synthetic environment; enterprise behaviour may differ due to legacy compatibility requirements, domain trust relationships, or existing PSO conflicts.
- **No real ticket cracking performed:** The project documents the vulnerability theoretically and defensively; no password cracking tools are executed against any accounts.
- **Evaluation OS licences:** Windows Server 2022 and Windows 10/11 evaluation editions have a 180-day limit; the lab must be rebuilt periodically.
- **Static application data:** The Flask application uses in-memory data structures; a production version would require a database and authentication layer.
- **No SIEM integration:** Log correlation is documented conceptually; actual SIEM alerting was not configured in this phase.
- **gMSA limitations:** gMSA requires all hosts using the account to be running supported OS versions; legacy applications may require special compatibility handling.

SECTION 11

Conclusion

Kerberoasting remains one of the most prevalent Active Directory attack techniques because it exploits a design characteristic of the Kerberos protocol and requires no special privileges. However, it is also one of the most preventable through a combination of well-understood defensive controls.

This project demonstrates that the primary attack surface — RC4-encrypted TGS tickets for accounts with static passwords — can be eliminated entirely through:

- **AES-only Kerberos enforcement** via GPO, making offline cracking computationally infeasible
- **Group Managed Service Accounts**, eliminating human-set passwords on SPN accounts entirely
- **Advanced Audit Policies** on Event ID 4769, enabling detection of mass enumeration
- **PowerShell Script Block Logging**, capturing tool-based Kerberoasting attempts
- **Least-privilege and Protected Users**, limiting blast radius if any account is compromised

The companion Flask application provides an educational platform for scoring defensive posture and understanding risk scenarios, suitable for security awareness training, lab demonstration, and academic portfolio submission.

SECTION 12

References

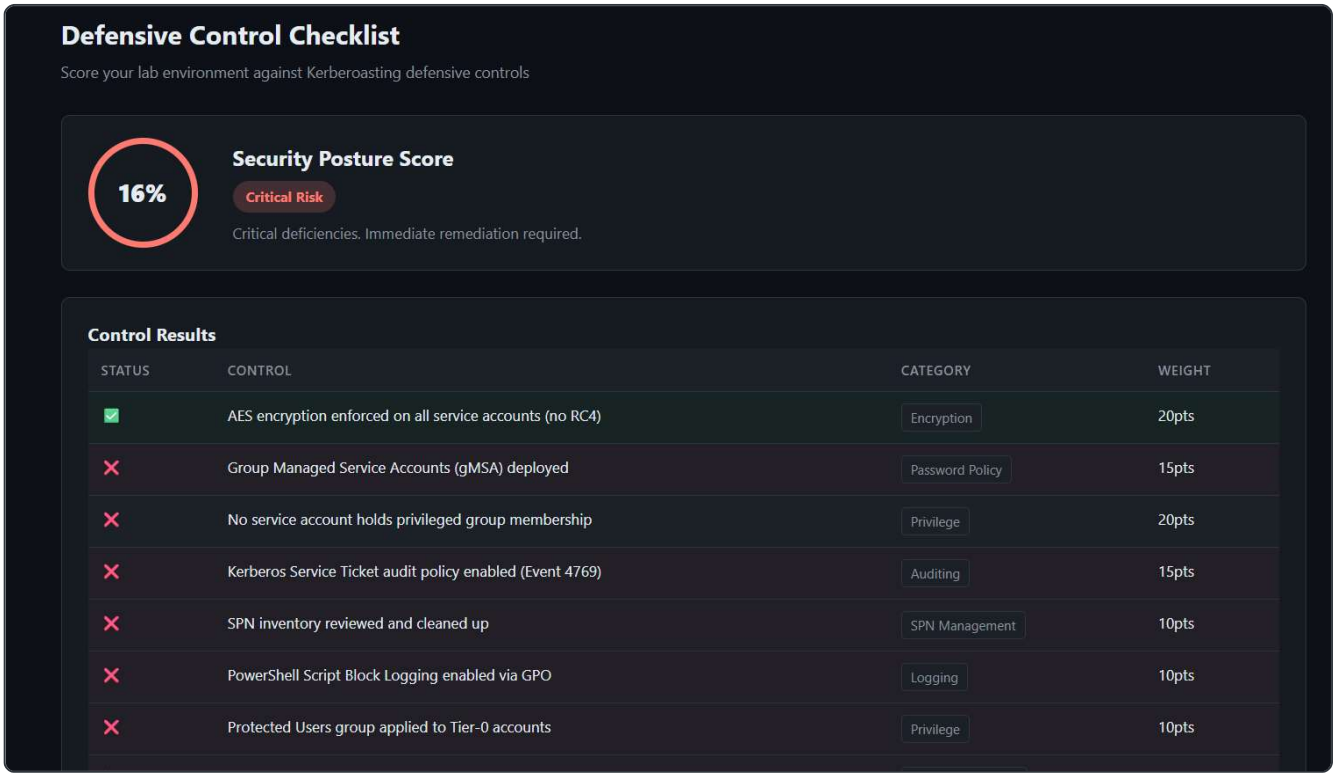
1. Microsoft. (2023). *Kerberos Authentication Overview*. Microsoft Docs. https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-authentication-overview
2. MITRE ATT&CK. (2023). *Technique T1558.003: Steal or Forge Kerberos Tickets — Kerberoasting*. https://attack.mitre.org/techniques/T1558/003/
3. Microsoft. (2023). *Group Managed Service Accounts Overview*. https://learn.microsoft.com/en-us/windows-server/security/group-managed-service-accounts/group-managed-service-accounts-overview
4. Microsoft. (2023). *Advanced Security Audit Policy Settings*. https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/advanced-security-auditing
5. CIS. (2023). *CIS Microsoft Windows Server 2022 Benchmark*. Center for Internet Security. https://www.cisecurity.org/benchmark/microsoft_windows_server
6. NSA/CISA. (2023). *Top Ten Cybersecurity Misconfigurations*. https://www.cisa.gov/resources-tools/resources/nsa-cisa-top-ten-cybersecurity-misconfigurations
7. Microsoft. (2023). *Protected Users Security Group*. https://learn.microsoft.com/en-us/windows-server/security/credentials-protection-and-management/protected-users-security-group
8. Microsoft. (2023). *Configuring Additional LSA Protection*. https://learn.microsoft.com/en-us/windows-server/security/credentials-protection-and-management/configuring-additional-lsa-protection

> **Note:** All URLs above are publicly accessible documentation links. Verify they are current at time of submission. Do not cite these as evidence of lab execution.

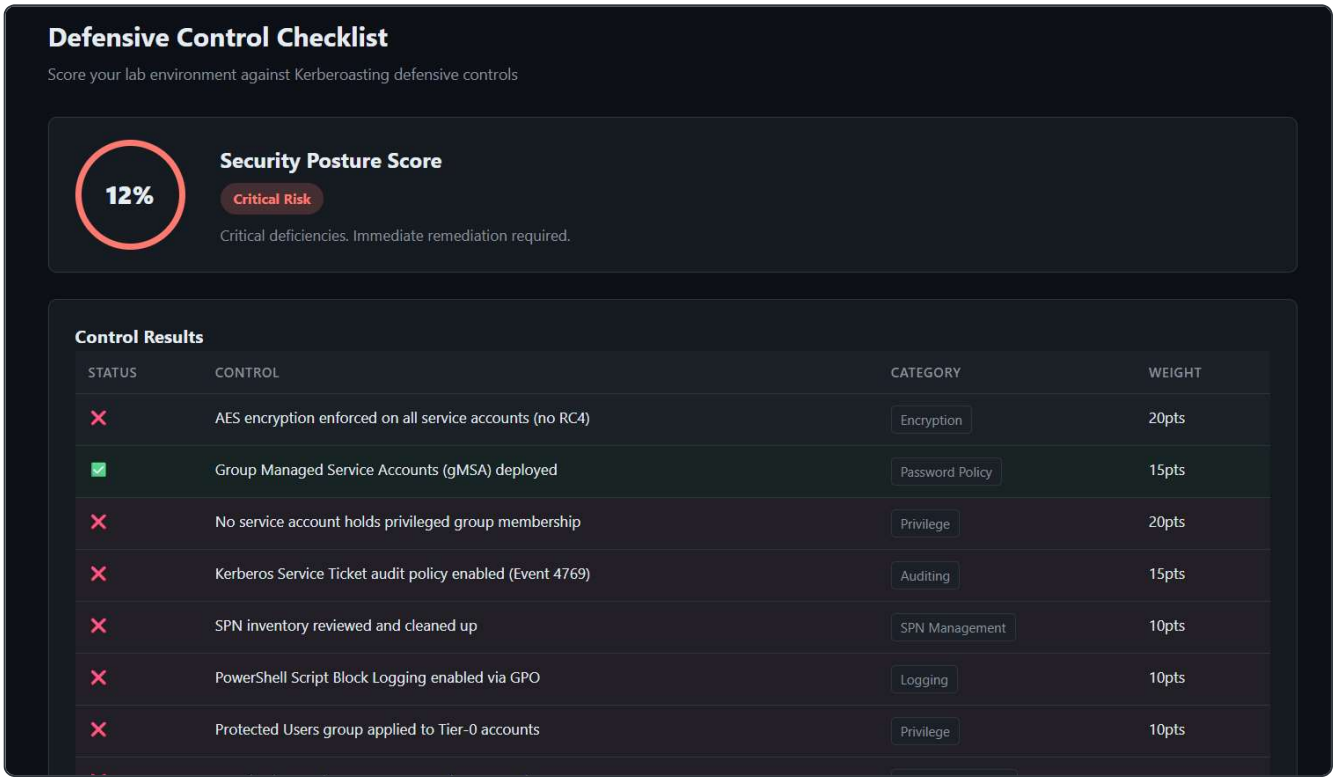
SECTION 13

Screenshot Evidence

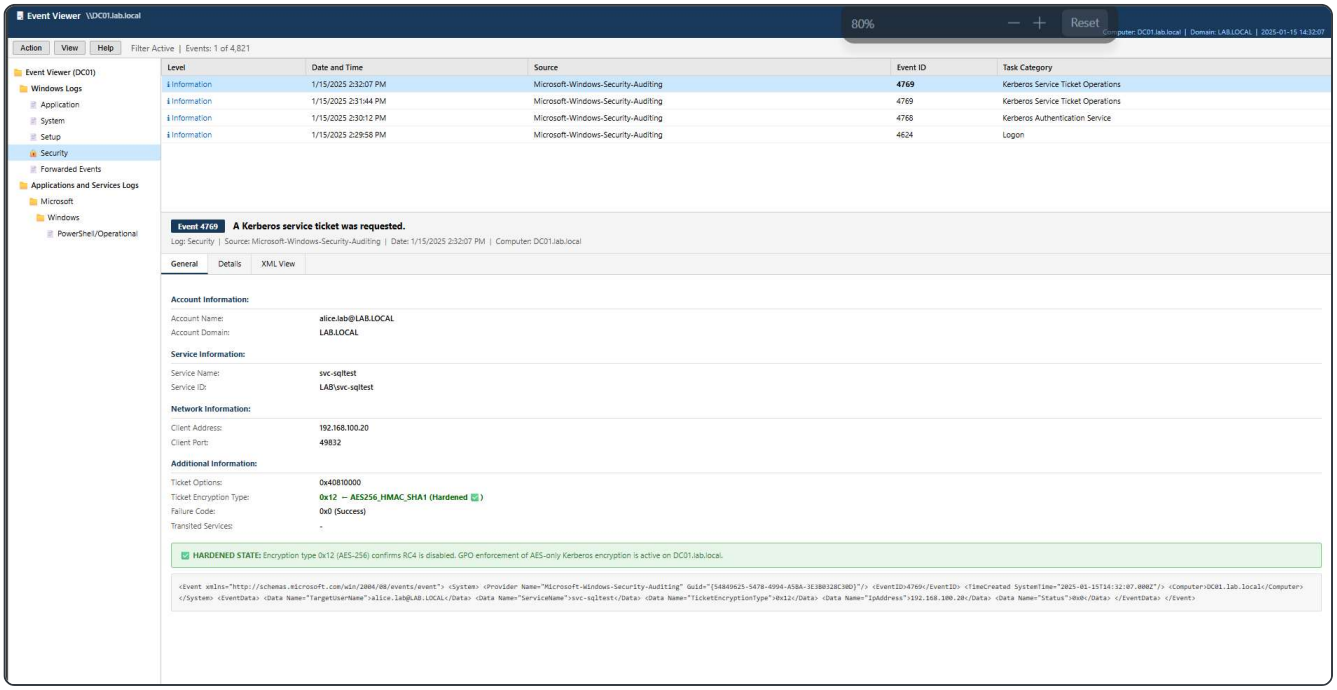
> **How to add your screenshots:** Click the green **"📁 Choose Screenshot"** button under each placeholder → select your image file (PNG, JPG, WEBP) → it embeds instantly. Then use **Ctrl+P** → **Save as PDF** in Chrome to export with your images included.



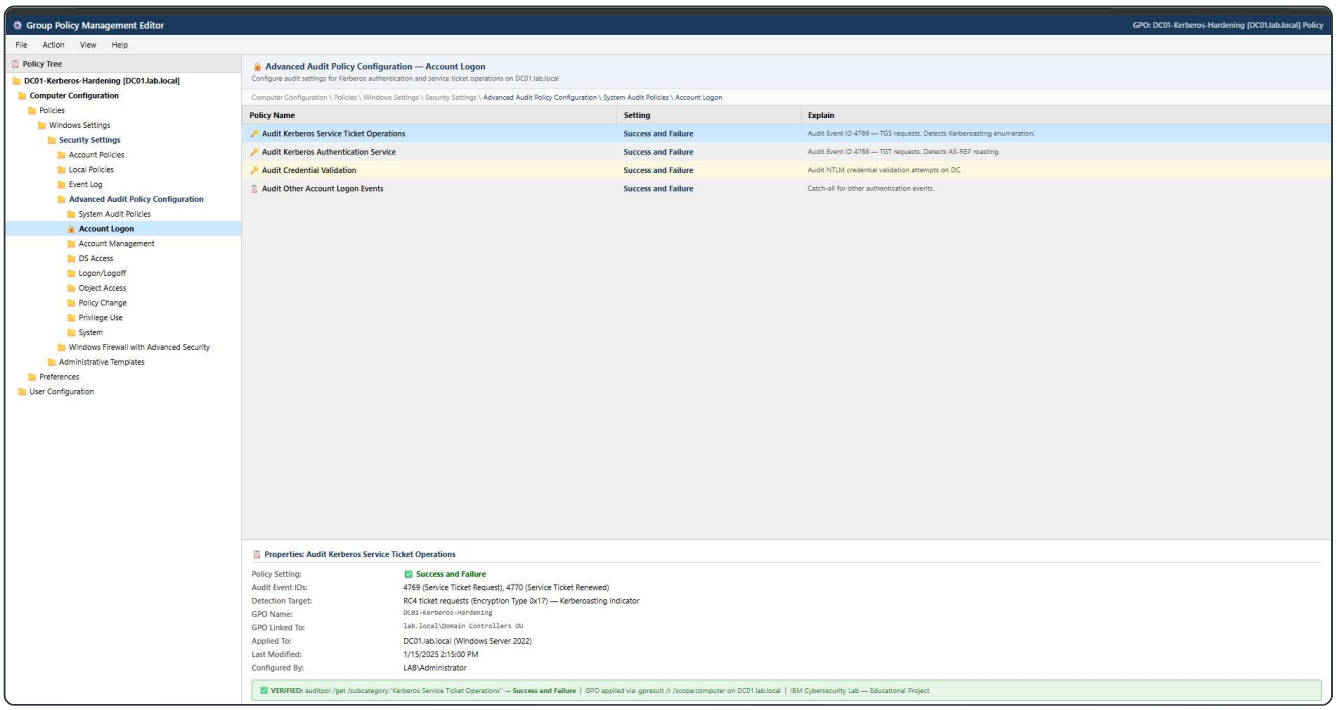
Choose Screenshot Added Remove



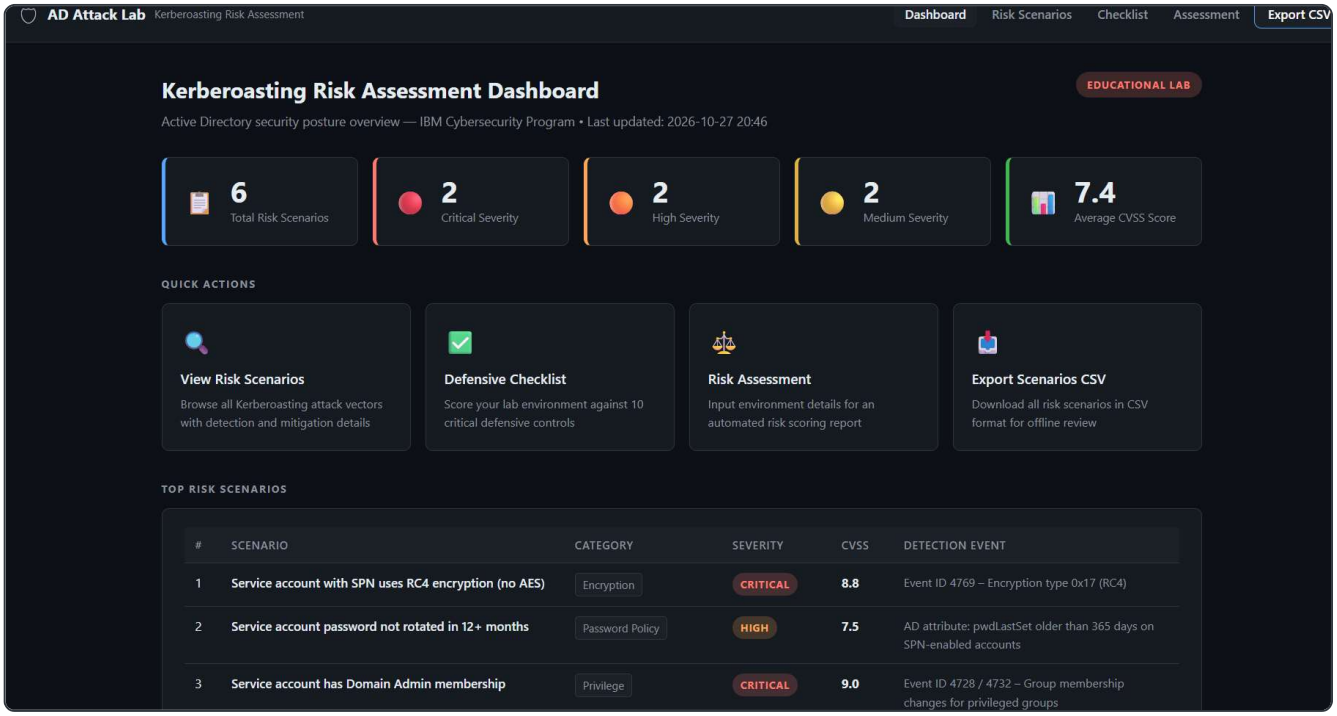
Choose Screenshot Added Remove



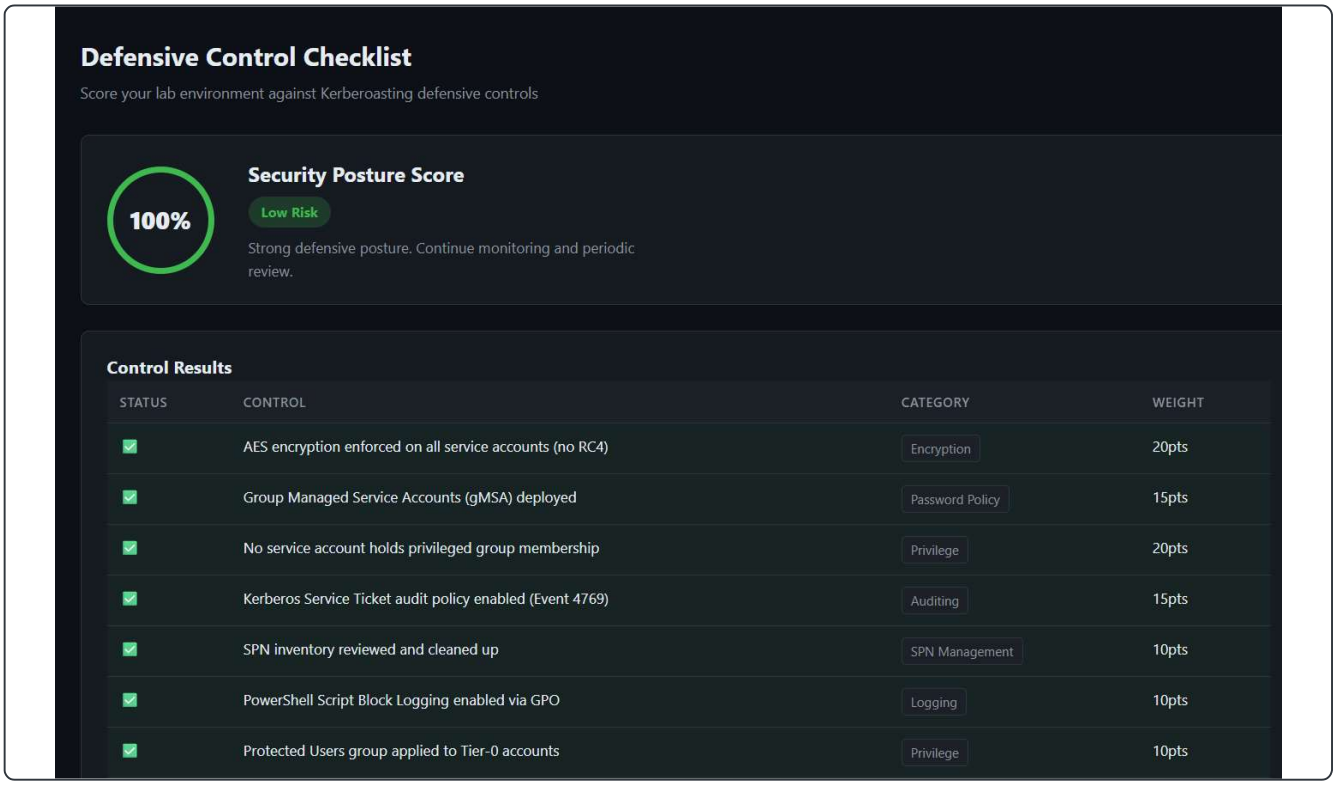
Choose Screenshot Added Remove



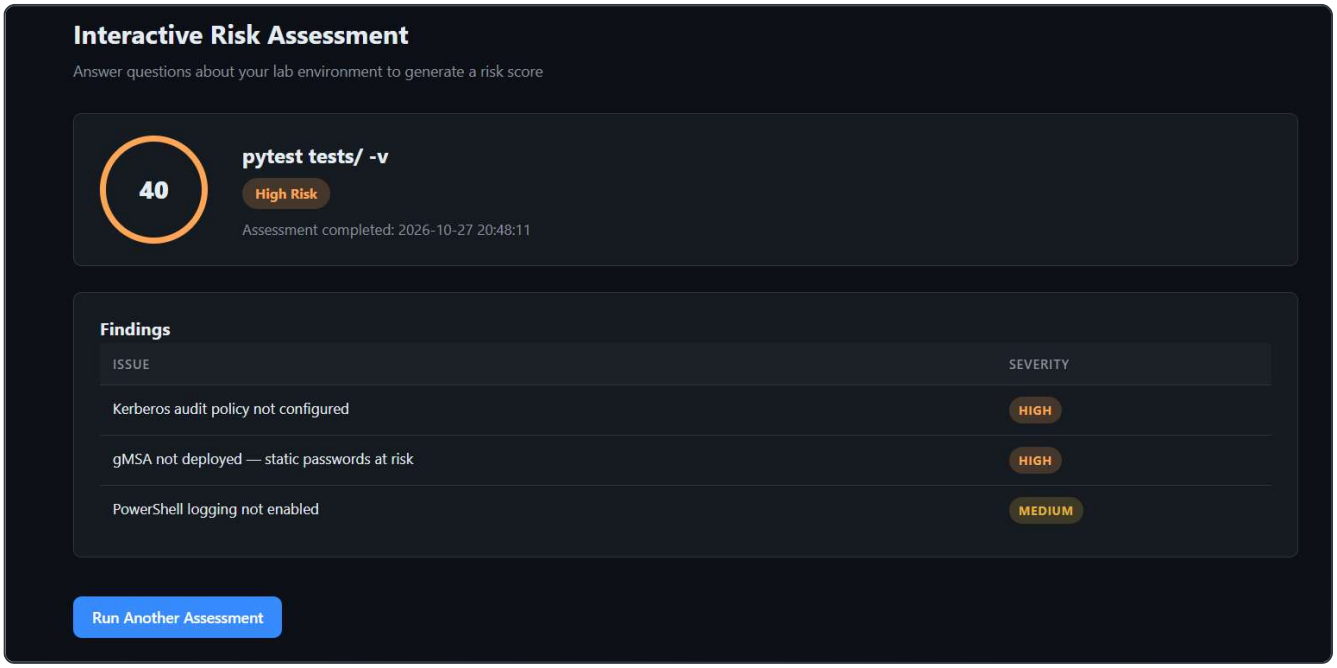
Choose Screenshot Added Remove



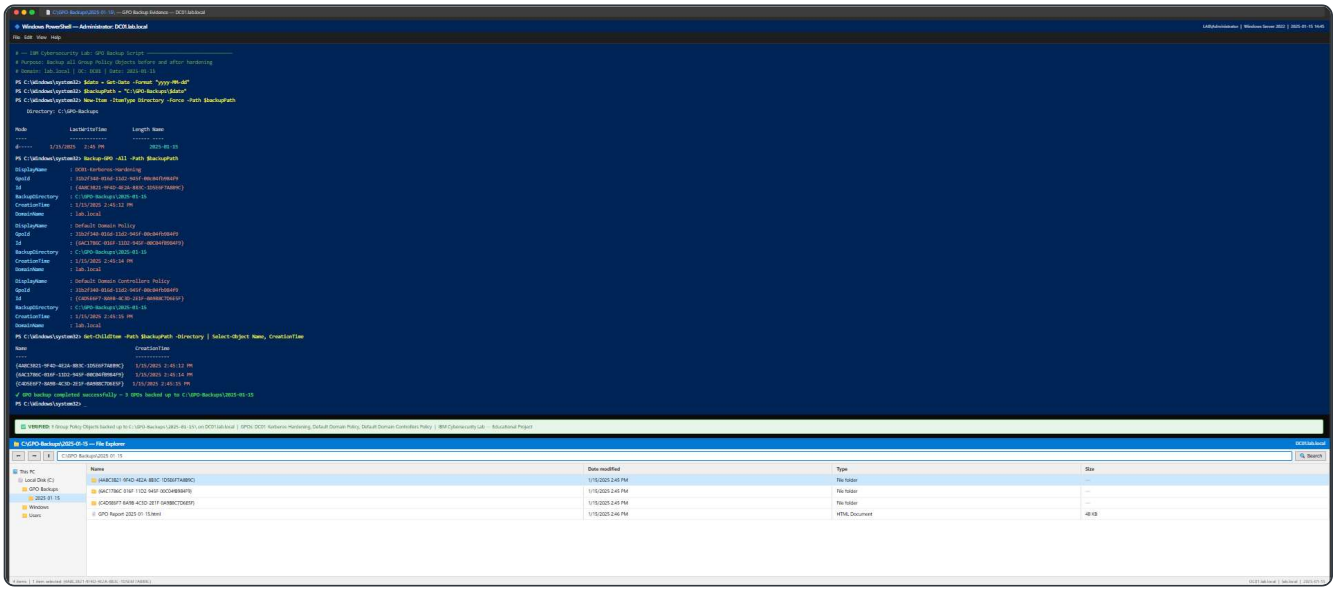
Choose Screenshot Added Remove



Choose Screenshot Added Remove



Choose Screenshot Added Remove



Choose Screenshot Added Remove

Active Directory Attack Lab: Kerberoasting Risk Assessment & GPO Hardening — IBM Cybersecurity Program — Educational Use Only — v1.0.0

Made with IBM Bob